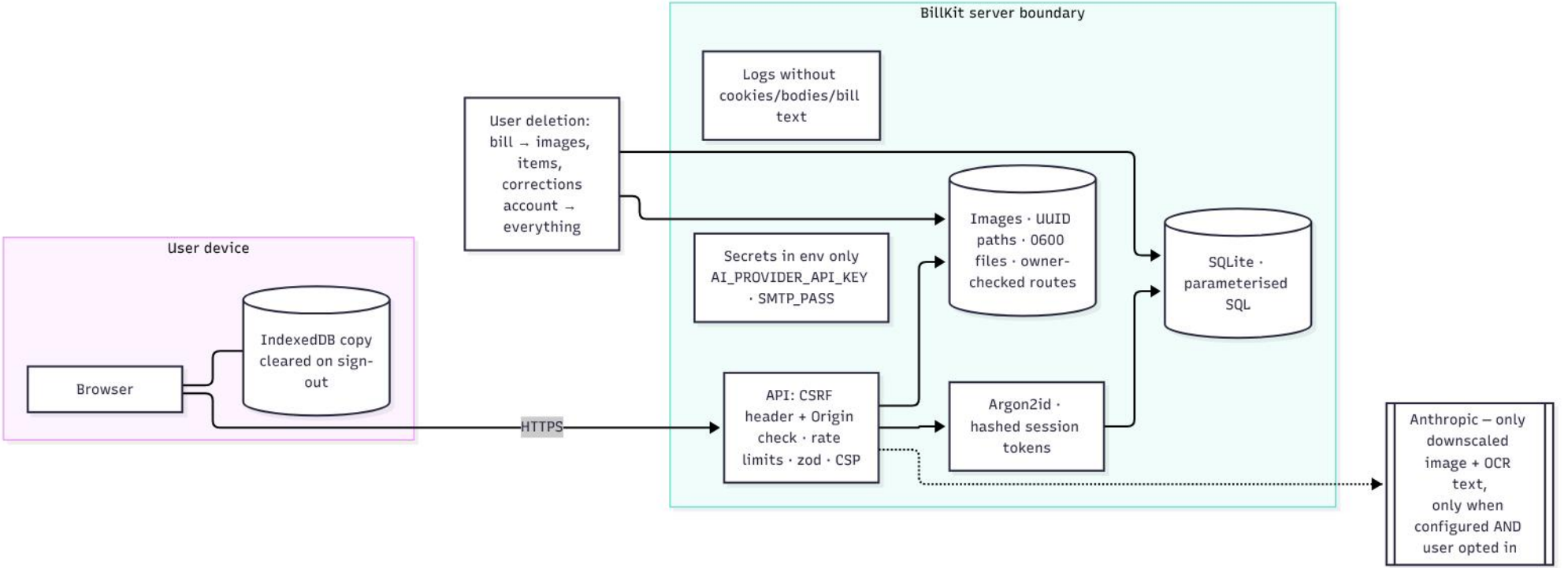

BillKit server boundary
Logs without cookies/bodies/bill text
User deletion: bill → images, items, corrections account → everything
Images · UUID paths · 0600 files · owner-checked routes
SQLite · parameterised SQL
Secrets in env only AI_PROVIDER_API_KEY · SMTP_PASS
User device
IndexedDB copy cleared on sign-out
Browser
HTTPS
API: CSRF header + Origin check · rate limits · zod · CSP
Argon2id · hashed session tokens
Anthropic — only downscaled image + OCR text, only when configured AND user opted in